SOFTWARE SECURITY LABORATORY
HANYANG UNIVERSITY

정보보안 정책 및 법규

2025년 2학기
컴퓨터보안
한양대학교 컴퓨터소프트웨어학부
임을규

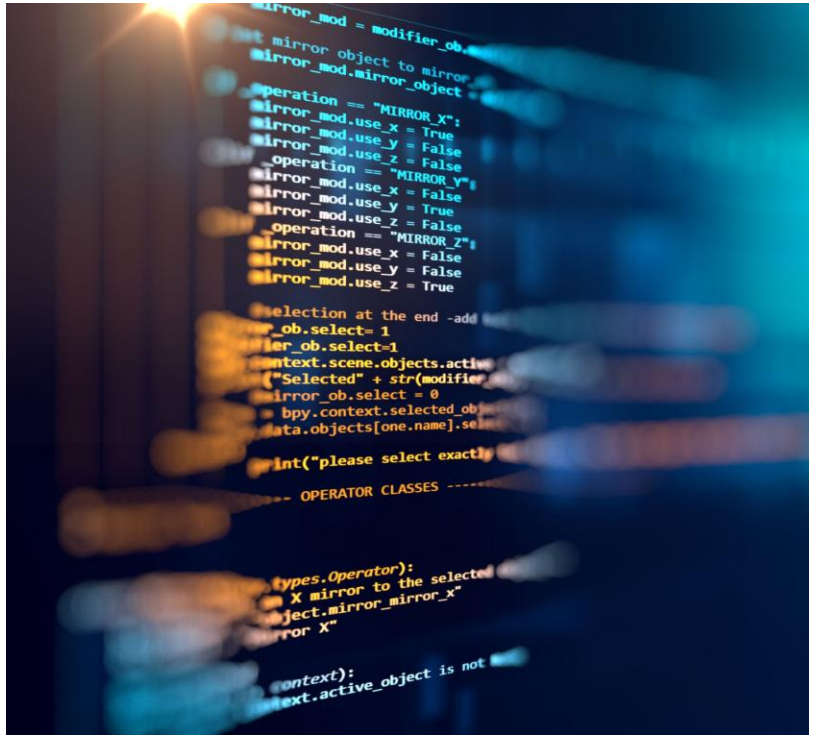
법규

- 법
  - 국회에서 정함. 예) 개인정보보호법
- 시행령
  - 상위 법에 대한 구체적인 내용을 기술. 행정부에서 정함
  - 대통령령
- 지침, 규정
  - 상위 법령에 따라 구체적인 해당 기관의 내용을 반영
  - 예) 국가정보보안 기본 지침
- 가이드라인

소프트웨어 개발 보안 가이드라인

주요 내용

- 소프트웨어 개발 보안 방법론
- 분석-설계 단계 보안 강화 활동
- 입력 데이터 검증 및 표현
- 보안 기능
- 코드 오류

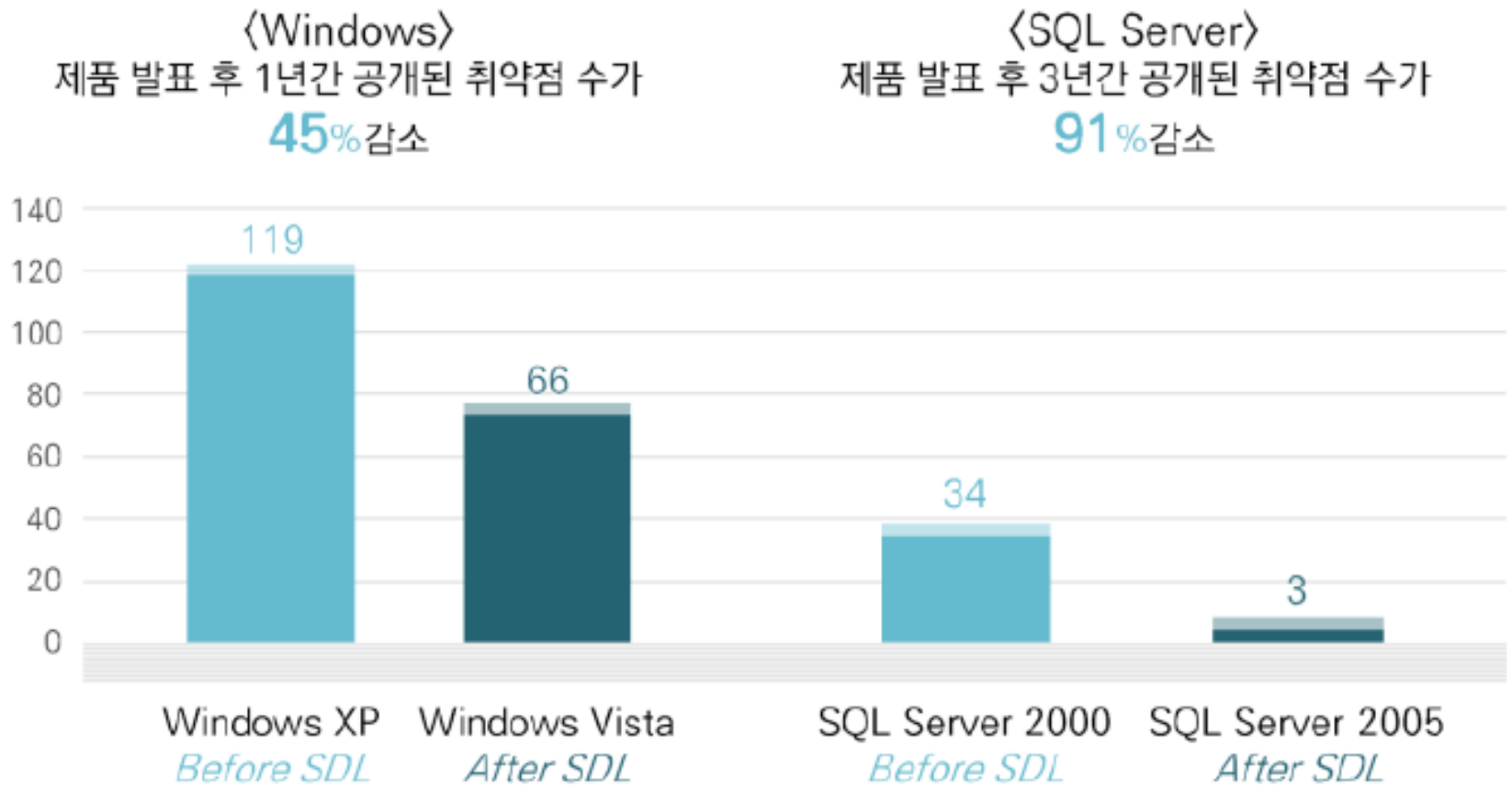


소프트웨어 보안 취약점

- SW 보안 취약점은 다음의 경우에 발생한다.
  - 보안 요구사항이 정의되지 않았거나,
  - 설계에 논리적인 오류가 있거나,
  - 보안에 취약한 코딩 규칙을 적용하였거나,
  - 소프트웨어 배치가 적절하지 않았거나,
  - 발견된 취약점에 대해 적절한 관리 또는 패치를 하지 않은 경우

소프트웨어 개발 생명 주기

소프트웨어 개발 보안 적용 효과



※ Sources: Microsoft Security Blog and Microsoft TechNet Security Blog

외부환경 분석(법, 규정 등)에 따른 보안 항목 식별

표 3-1 개인정보보호 관련 법규

관련법규	주요내용
개인정보 보호법	• 개인정보의 처리 및 보호에 관한 사항을 규정
신용정보의 이용 및 보호에 관한 법률	• 개인 신용정보의 취급 단계별 보호조치 및 의무사항에 관한 규정
위치정보의 보호 및 이용 등에 관한 법률	• 개인위치정보 수집, 이용, 제공 파기 및 정보주체의 권리 등 규정
표준 개인정보보호 지침 (표준지침)	• 「개인정보 보호법」 제12조제1항에 따른 개인정보의 처리에 관한 기준, 개인정보 침해의 유형 및 예방조치 등에 관한 세부적인 사항을 규정
개인정보의 안전성 확보 조치 기준 고시	• 「개인정보보호법」 제23조제2항, 제24조제3항 및 제29조와 같은 법 시행령 제21조 및 제30조에 따라 개인정보처리자가 개인정보를 처리함에 있어서 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 안전성 확보에 필요한 기술적·관리적 및 물리적 안전조치에 관한 최소한의 기준을 규정
개인정보 영향평가에 관한 고시	• 「개인정보 보호법」 제33조와 같은 법 시행령 제38조에 따른 평가기관의 지정 및 영향평가의 절차 등에 관한 세부기준 규정

설계 단계 보안 설계 기준

◆ 입력 데이터 검증 및 표현

번호	설계항목	설명	비고
1	DBMS 조회 및 결과 검증	• DBMS 조회시 질의문(SQL) 내 입력값과 그 조회결과에 대한 유효성 검증방법(필터링 등) 설계 및 유효하지 않은 값에 대한 처리방법 설계	입출력 검증
2	XML조회 및 결과 검증	• XML 조회시 질의문(XPath, XQuery 등) 내 입력값과 그 조회결과에 대한 유효성 검증방법(필터링 등) 설계 및 유효하지 않은 값에 대한 처리방법 설계	
3	디렉토리 서비스 조회 및 결과 검증	• 디렉토리 서비스(LDAP 등)를 조회할 때 입력값과 그 조회결과에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계	
4	시스템 자원 접근 및 명령어 수행 입력값 검증	• 시스템 자원접근 및 명령어를 수행할 때 입력값에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계	
5	웹 서비스 요청 및 결과 검증	• 웹 서비스(게시판 등) 요청(스크립트 게시 등)과 응답결과 (스크립트를 포함한 웹 페이지)에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계	
6	웹 기반 중요 기능 수행 요청 유효성 검증	• 비밀번호 변경, 결제 등 사용자 권한 확인이 필요한 중요기능을 수행할 때 웹 서비스 요청에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계	
7	HTTP 프로토콜 유효성 검증	• 비정상적인 HTTP 헤더, 자동연결 URL 링크 등 사용자가 원하지 않은 결과를 생성하는 HTTP 헤더·응답결과에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계	
8	허용된 범위내 메모리 접근	• 해당 프로세스에 허용된 범위의 메모리 버퍼에만 접근하여 읽기 또는 쓰기 기능을 하도록 검증방법 설계 및 메모리 접근 요청이 허용범위를 벗어났을 때 처리방법 설계	
9	보안기능 입력값 검증	• 보안기능(인증, 권한부여 등) 입력 값과 함수(또는 메소드)의 외부입력값 및 수 행결과에 대한 유효성 검증방법 설계 및 유효하지 않은 값에 대한 처리방법 설계	
10	업로드·다운로드 파일 검증	• 업로드·다운로드 파일의 무결성, 실행권한 등에 관한 유효성 검증방법 설계 및 부적합한 파일에 대한 처리방법 설계	파일 검증

설계 단계 보안 설계 기준

◆ 보안 기능

- 인증, 접근통제, 권한관리, 비밀번호 등의 정책이 적절하게 반영될 수 있도록 설계

번호	설계항목	설명	비고
1	인증 대상 및 방식	• 중요정보·기능의 특성에 따라 인증방식을 정의하고 정의된 인증방식을 우회하지 못하게 설계	인증 관리
2	인증 수행 제한	• 반복된 인증 시도를 제한하고 인증 실패한 이력을 추적하도록 설계	
3	비밀번호 관리	• 생성규칙, 저장방법, 변경주기 등 비밀번호 관리정책별 안전한 적용 방법 설계	
4	중요자원 접근통제	• 중요자원(프로그램 설정, 민감한 사용자 데이터 등)을 정의하고, 정의된 중요자원에 대한 신뢰할 수 있는 접근통제 방법(권한관리 포함) 설계 및 접근통제 실패 시 처리방법 설계	접근 권한 관리
5	암호키 관리	• 암호키 생성, 분배, 접근, 파기 등 암호키 생명주기별 암호키 관리 방법을 안전하게 설계	암호 관리
6	암호연산	• 국제표준 또는 검증필 암호모듈로 등재된 안전한 암호 알고리즘을 선정하고 충분한 암호키 길이, 솔트, 충분한 난수값을 적용한 안전한 암호연산 수행방법 설계	
7	중요정보 저장	• 중요정보(비밀번호, 개인정보 등)를 저장·보관하는 방법이 안전하도록 설계	중요 정보 처리
8	중요정보 전송	• 중요정보(비밀번호, 개인정보, 쿠키 등)를 전송하는 방법이 안전하도록 설계	

구현 단계 보안 취약점 제거

입력데이터 검증 및 표현	보안기능	에러처리	세션통제

입력 데이터 검증 및 표현 (17개)	SQL 삽입	코드 삽입	경로 조작 및 자원 삽입	크로스사이트 스크립트	운영체제 명령어 삽입	위험한 형식 파일 업로드
	신뢰되지 않은 URL 주소로 자동 접속 연결	부적절한 XML 외부개체 참조	XML 삽입	LDAP 삽입	크로스사이트 요청 위조	서버사이드 요청 위조
	HTTP 응답 분할	정수형 오버플로우	보안기능 결정에 사용되는 부적절한 입력값	메모리 버퍼 오버플로우	포맷 스트링 삽입	
보안 기능 (16개)	적절한 인증없는 중요 기능 허용	부적절한 인가	중요한 자원에 대한 잘못된 권한 설정	취약한 암호화 알고리즘 사용	암호화되지 않은 중요정보	하드코드된 중요정보
	충분하지 않은 키 길이 사용	적절하지 않은 난수값 사용	취약한 비밀번호 허용	부적절한 전자서명 확인	부적절한 인증서 인증서 유효성 검증	사용자 하드 디스크에 저장되는 쿠키를 통한 정보 노출
	주석문 안에 포함된 시스템 주요정보	솔트 없이 일방향 해쉬 함수 사용	무결성 검사 없는 코드 다운로드	반복된 인증시도 제한 기능 부재		
시간 및 상태 (2개)	경쟁조건: 검사 시점과 사용 시점(TOCTOU)	종료되지 않은 반복문 재귀함수				
에러처리 (3개)	오류메시지 정보 노출	오류 상황 대응 부재	부적절한 예외 처리			
코드오류 (5개)	Null Pointer 역참조	부적절한 자원해제	해제된 자원 사용	초기화되지 않은 변수 사용	신뢰할 수 없는 데이터의 역직렬화	
캡슐화 (4개)	잘못된 세션에 의한 데이터 정보노출	제거되지 않고 남은 디버그 코드	Public 메소드 부터 반환된 Private 배열	private 배열에 public 데이터 할당		
API 오용 (2개)	DNS Lookup에 의존한 보안 결정	취약한 API 사용				

SW 공급망 보안 가이드라인

필요성

- 디지털 제품 및 서비스에 포함된 악성코드 또는 보안취약점은 사전에 탐지하기가 어렵고, 사고가 발생하면 광범위한 피해와 함께 사고가 연이어 발생하는 특징을 갖음.
- 공개 SW로 널리 활용되는 Log4j에서 초고도 보안취약점이 발견된 사건(2021년)은 국내외에 큰 충격을 주었고, 공개 SW의 보안 강화를 추진하게 하는 계기가 됨.
  - Log4j는 Java로 작성된 프로그램의 로그를 기록하는 라이브러리
- 미국은 바이든 행정부의 행정명령(EO 14028, ‘21.5월) 이후 보안관리 자체증명서를 제출하도록 제도화하였음.
- EU는 SW 공급망 보안을 의무화하는 사이버 복원력법 제정 발의(‘22.9월) 후 EU 의회 및 이사회의 의결(‘24.3월) 등 제도화를 추진 중

SW 공급망

◆ SW 부품 공급의 분업화

그림 2 전통적인 공급망과 SW 공급망 비교

◆ 오픈 소스의 사용 확대

그림 3 2024년도 사이버보안 위협분석과 전망 리포트[KISA]

사고 사례

◆ 국내외 사고 사례 및 피해 규모

공격명 (발생 시기)	사고 내용 및 피해 현황
SolarWinds (2020년)	러시아 기반 해킹 그룹의 공격으로 IT SW 공급사의 SW 개발환경 및 배포 시스템이 해킹되어 18,000개 이상의 기관이 피해를 입음
Codecov (2021년)	컨테이너 이미지 보안취약점을 악용해 소스코드 검증을 위한 배포 환경의 인증 정보가 유출, 전 세계 2만 9천여 개 고객사에 영향을 끼침
Colonial Pipeline (2021년)	송유관 관리사의 IT 시스템이 랜섬웨어에 감염되어 미국 남동부 8,900km 일대 공급이 중단, 지역 비상사태 선포와 약 50억 원의 랜섬머니(Ransom Money) 지급 발생
Log4Shell (2021년)	Log4j의 제로데이 보안취약점과 공개된 개념 증명 코드를 악용하여 악성코드를 심고, 전 세계 취약 서버를 대상으로 대량의 해킹 공격 발생
Kaseya (2022년)	클라우드 기반 IT 원격 관리 솔루션 서버를 해킹하고, 업데이트 파일로 위장한 랜섬웨어를 고객사에 배포, 17개국 1,500여 조직이 피해
3CX (2023년)	악성코드가 삽입된 X-트레이더 금융 SW를 다운받은 PC를 감염시켜 60만 명 이상의 고객과 1,200만 개 조직으로 전파
이니세이프 (2023년)	금융 보안인증 SW의 보안취약점을 악용해 PC 해킹 및 악성코드 유포로 국내 61개 기관, 총 207대의 기관, 기업, 개인 PC 해킹 피해

SW 공급망 공급 유형

유형	세부 내용
1. 공개 SW 보안취약점 (Vulnerabilities in OSS)	공개 SW에 취약한 코드 또는 유해한 구성요소가 포함되어 취약성이 공개 SW를 사용하는 모든 SW에 전파
2. 타사 의존성 (3rd Party Dependencies)	공격자가 타사 SW(상용 SDK, 라이브러리 또는 컴포넌트13))에 악성코드를 삽입하여 이를 악용하는 운영 시스템을 침해
3. 공용 리포지토리 (Public Repositories)	공개 SW 코드를 찾는 개발자를 목표로 GitHub 등 알려진 리포지토리 호스팅 서비스에 합법적인 SW 패키지와 유사한 이름을 가진 악성코드를 업로드
4. 변환 시스템 (Build Systems)	개발 프로세스 자동화를 위한 CI/CD 상의 중요 코드, 리포지토리, 컨테이너 및 변환 서버를 침해하여 악성코드로 교체
5. 업데이트 가로채기 (Hijacking Updates)	공격자가 SW 업데이트 과정을 침해하거나 업데이트 서버의 관리 권한을 가로채어 악성코드를 삽입
6. 내부 리포지토리 (Private Repositories)	공격자가 기업 내부에서 사용 중인 코드 저장소에 침입하여 악성코드를 삽입
7. 공급사 및 협력사 (Suppliers and Business Partners)	SW 부품 또는 완제품 개발사, 공급사 등으로부터 외부 서비스를 제공받는 경우 관리되지 않는 타사 위험(Risk)이 내부 시스템으로 전이

SBOM = SW Bill of Materials

표 13 SBOM과 기타 BOM 명세서와 비교

구분	적용 분야	사용 목적
Food ingredients	식품	공급(유통)되는 식품에 관한 소비자의 위험 성분 확인
BOM	제조업	지속적인 양산 체제 유지를 위한 부품 관리와 자동화
SBOM	SW	공급망 위험관리를 위한 투명한 SW 구성요소 정보 제공

그림 11 SBOM 활용의 효과성

시큐어 코딩 가이드 라인

행정안전부 가이드라인

- 시큐어코딩가이드(C, Java) - 2014년
  - 행정안전부> 정책자료> 간행물> 간행물
  - https://www.mois.go.kr/frt/bbs/type001/commonSelectBoardArticle.do?bbsId=BBSMSTR_000000000012&nttId=42152

MISRA

- 임베디드 시스템과 소프트웨어에 대한 안전한 가이드라인을 제공하고 있음.
- MISRA C 2020
  - https://www.misra.org.uk/misra-c/

MISRA

The **MISRA Compliance:2020** document provides guidelines for achieving compliance with MISRA coding standards, widely used in safety- and security-critical software development. Here's a high-level summary:

- **Purpose & Scope**
  - MISRA guidelines ensure safe and secure application development, primarily in **C and C++**.
  - The document defines what it means to be **MISRA compliant** and how to structure a compliance framework.
- **Software Development Process**
  - Compliance should be embedded from the start of development.
  - Includes training, style guides, tool management, and run-time behavior considerations.
  - Selection and validation of **compilers and static analysis tools** are crucial.
- **Fundamentals of Compliance**
  - Guidelines are categorized as **Rules (enforceable by tools)** or **Directives (requiring human review)**.
  - Scope of enforcement: Some rules are checked **per file (translation unit)**, while others require **system-wide analysis**.
  - **Guideline Enforcement Plan (GEP)** ensures systematic rule checking.
- **Handling Deviations**
  - Compliance does not mean strict adherence to all rules—**deviations are allowed** if justified and documented.
  - **Deviation records and permits** track rule violations and their justifications.
  - Common reasons for deviations:
    - **Code Quality Improvements**
    - **Hardware Access Needs**
    - **Integration of Third-Party Code**
    - **Adoption of Legacy Code**

MISRA

- **Guideline Re-Categorization**
  - Projects may adjust MISRA rule categories to better fit their needs.
  - Categories:
    - **Mandatory** – Cannot be violated.
    - **Required** – Can be violated only with documented deviations.
    - **Advisory** – Best practices, but violations don't need formal deviations.
    - **Disapplied** – Not relevant for the project.
- **Adopted Code & Compliance Challenges**
  - **Third-party, legacy, and library code** may not be fully compliant.
  - Special considerations for **binary-only** code since it cannot be checked for MISRA compliance.
- **Claiming Compliance**
  - Compliance can only be claimed at the **project level**, not organization-wide.
  - Requires:
    - Staff competency and training.
    - Proper deviation management.
    - **Guideline Compliance Summary (GCS)** to document rule adherence.
- **Appendix: Checklist & Examples**
  - Appendix sections include a **compliance checklist**, example **deviation records**, and example **deviation permits**.
- **Conclusion:**
  - MISRA Compliance:2020 provides a **structured framework** for ensuring software safety, security, and maintainability through disciplined **coding standards, tools, and deviation management**. Proper enforcement reduces software defects, enhances reliability, and supports regulatory requirements in industries such as **automotive, aerospace, and medical devices**.

개인 정보 보호 관련 법규

개인 정보 보호 관련 법규

◆ 개인 정보 = 개인을 식별할 수 있는 정보

표 3-1 개인정보보호 관련 법규

관련법규	주요내용
개인정보 보호법	• 개인정보의 처리 및 보호에 관한 사항을 규정
신용정보의 이용 및 보호에 관한 법률	• 개인 신용정보의 취급 단계별 보호조치 및 의무사항에 관한 규정
위치정보의 보호 및 이용 등에 관한 법률	• 개인위치정보 수집, 이용, 제공 파기 및 정보주체의 권리 등 규정
표준 개인정보보호 지침 (표준지침)	• 「개인정보 보호법」 제12조제1항에 따른 개인정보의 처리에 관한 기준, 개인정보 침해의 유형 및 예방조치 등에 관한 세부적인 사항을 규정
개인정보의 안전성 확보 조치 기준 고시	• 「개인정보보호법」 제23조제2항, 제24조제3항 및 제29조와 같은 법 시행령 제21조 및 제30조에 따라 개인정보처리자가 개인정보를 처리함에 있어서 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 안전성 확보에 필요한 기술적·관리적 및 물리적 안전조치에 관한 최소한의 기준을 규정
개인정보 영향평가에 관한 고시	• 「개인정보 보호법」 제33조와 같은 법 시행령 제38조에 따른 평가기관의 지정 및 영향평가의 절차 등에 관한 세부기준 규정

데이터 3법

- 개인정보보호법, 정보통신망법, 신용정보법
- 데이터 산업 활성화를 위하여 개정안이 통과되어 2020년 8월부터 시행됨.
- 핵심 내용
  - 가명 정보, 익명정보 개념 도입
  - 가명 정보를 연구 및 공익 목적으로 활용가능하도록 함

개인정보 보호법 주요 개정 사항

한 눈에 보는 개정 개인정보 보호법

목차	주요 내용
제1장총칙	목적, 정의, 보호 원칙, 정보주체의 권리
제2장 개인정보 보호정책의 수립 등	개인정보호위원회의 구성, 업무 등
제3장 개인정보의 처리	
제1절 개인정보의 수집, 이용, 제공 등	개인정보의 **수집·이용, 제공**, 수집 출처 통지, **이용·제공 내역 통지**, 파기, **아동의 개인정보보호**
제2절 개인정보의 처리 제한	민감정보, 고유식별정보, 주민등록번호, [고정형, **이동형] 영상처리기기, 개인정보 처리위탁**
제3절 가명정보의 처리에 관한 특례	가명정보 처리, 결합, 안전조치, 적용 제외
제4절 개인정보의 국외 이전	**개인정보 국외 이전 요건, 국외 이전 중지**
제4장 개인정보의 안전한 관리	**안전조치, 개인정보 처리방침, CPO/국내대리인**, ISMS-P, **영향평가, 유출통지·신고**, 노출 삭제
제5장 정보주체의 권리 보장	열람권, 정정·삭제권, **처리정지권, 동의철회권, 전송요구권, 자동화된 의사결정에 대한 정보주체의 권리보장, 손해배상**
제7장 개인정보 분쟁조정위원회	개인정보 분쟁조정위원회 구성, 업무, **조정 신청, 사실 조사, 분쟁 조정**
제8장 개인정보 단체소송	단체소송의 대상, 요건, 진행
제9장 보칙	적용 제외, **금지행위, 사전 실태점검, 과징금**, 고발 및 징계권고 , 개선권고
제10장 벌칙	**형사처벌, 과태료**

Q&A